

AUDITORIA TECNICA DE SEGURIDAD WEB

Informe de análisis de riesgos.



Heimdall Threat Advisory

Consultoría en ciberseguridad para empresas

Organización auditada: elsurtidor.com
Análisis de riesgos

INFORME DE ANÁLISIS DE RIESGOS Y AUDITORIA TECNICA DE SEGURIDAD WEB

Fecha del informe: Junio-15-2026.

Periodo de auditoria: [Junio-01-2026]-[Junio-14-2026].

Entidad auditada: elsurtidor.com

Auditor: José Ricardo Flores Martínez.

Responsable	Puesto	Fecha de entrega
	Director general	Junio 15 2026
	Gerente IT	Junio 15 2026
	Responsable de desarrollo	Junio 16 2026

Índice de contenido.

1. Pag 2 - Resumen ejecutivo (motivación, alcance, objetivos Y riesgo asumible).
2. Pag 5 – Puntos de mejora.
3. Pag 5 – Plan y opciones de tratamiento.
4. Pag 7 – Modelado de amenazas.
4. Pag 10- Seguimiento.
5. Pag 10- Conclusiones.
6. Pag 10- Limitaciones y responsabilidades.

1. Resumen ejecutivo.

El presente informe corresponde al análisis de riesgos derivado de la auditoría técnica ejecutada sobre los activos expuestos a internet de elsurtidor.com. Tiene como objetivo identificar y evaluar los riesgos críticos de seguridad presentes en la infraestructura que puedan afectar la confidencialidad, integridad y disponibilidad de la información, así como la continuidad del negocio.

El análisis reveló que, a pesar de la implementación de controles perimetrales robustos como un servicio WAF, varios activos críticos quedaron fuera del perímetro de protección y son accesibles desde internet permitiendo la evasión de controles y habilitando posibles escenarios de ataque en cadena que podrían afectar la infraestructura entera.

Con el fin de facilitar la priorización de corrección de estos problemas, se identifican riesgos de nivel crítico asociados principalmente a la exposición directa de servicios internos y al uso de tecnologías obsoletas, los cuales requieren atención prioritaria para reducir la superficie de ataque global.

1.1 Contexto: La organización cuenta actualmente con 20 sucursales en diferentes estados de la república, con departamentos de IT segmentados en diferentes localidades.

Recientemente se implementó un proceso de migración de la plataforma a un servicio WAF que enmascara la dirección real del activo, limitando su acceso desde el exterior, fortaleciendo la seguridad de la infraestructura.

1.2 Riesgo asumible: Se asigna un valor de riesgo asumible de nivel 2: Riesgo bajo (Risk appetite) considerando el tipo de información que maneja la organización y el nivel de impacto al negocio en caso de materializarse alguno de los riesgos evaluados. Cualquier riesgo evaluado que sobrepase este nivel deberá ser tratado mediante las acciones de mitigación seleccionadas según el plan incluido en este informe mientras que aquellos dentro del rango “asumible” podrán mantenerse bajo los controles existentes, sujetos a reevaluación en caso de cambios en el entorno.

Nivel 1 (0 - 20): Riesgo insignificante / informativo.

Nivel 2 (21 - 40): Riesgo bajo / asumible.

Nivel 3 (41 - 60): Riesgo moderado / requiere atención.

Nivel 4 (61 - 80): Riesgo alto / requiere mitigación urgente.

Nivel 5 (81 - 100): Riesgo crítico / inaceptable.

1.3 Alcance: El análisis se enfoca y limita a los 3 activos detectados como accesibles sin necesidad de pasar por el perímetro de protección WAF durante el proceso de auditoria ejecutado en el periodo del 01 al 14 de Junio y las tecnologías albergadas en ellos. Estos activos se enumeran a continuación.

ID-Activo	Activo	Tipo	Tecnología	Exposición	Criticidad	Observaciones
A1	Servidor de correo (zb.elsurtidor.com)	Infraestructura	Zimbra + OpenLDAP	Pública (fuera WAF)	Alta	Servicios administrativos expuestos, LDAP vulnerable
A2	Servidor de correo (MX)	Infraestructura	Zimbra	Pública (fuera WAF)	Alta	Acceso directo por IP, elusión de WAF confirmado
A3	Plataforma de capacitación	Aplicación Web	Nginx + PHP 7.4.33 + Drupal 7	Pública (fuera WAF)	Alta	Tecnologías EOL, múltiples servicios expuestos
PDA	Sitio principal e-commerce	Aplicación Web	WAF (Cloudflare)	Protegida	Crítica	Correctamente protegido, pero dependiente de otros nodos

1.4 Riesgos identificados: Después del análisis de exposición y la aplicación de pruebas de concepto durante la auditoria, se definieron los siguientes riesgos ordenados según el nivel de riesgo determinado el cual corresponde al **impacto potencial** y la **probabilidad de ocurrencia** en el activo evaluado. Es importante tener en cuenta que los riesgos identificados **no deben** evaluarse de forma aislada, sino como parte de posibles escenarios de ataque encadenados, donde la explotación de una debilidad inicial puede facilitar el compromiso progresivo de otros activos.

ID Riesgo	Riesgo	Activo afectado	Probabilidad	Impacto	Nivel de Riesgo	Justificación
R1	Exposición fuera del perímetro WAF y acceso directo a servicios internos	A2	90	95	92-Crítico	Acceso directo confirmado al backend sin pasar por controles de seguridad
R2	Uso de tecnologías EOL (PHP, Drupal, OpenLDAP)	A1, A3	65	80	72-Alto	Amplia superficie de ataque con múltiples CVEs públicas
R3	Exposición de servicios críticos (BDD, VNC)	A3	70	85	77-Alto	Acceso parcial confirmado, riesgo de movimiento lateral
R4	Exposición de LDAP con acceso anónimo	A1	50	50	50-Mod	Permite enumeración y mapeo interno de la organización
R5	Ejecución remota de código en Zimbra (potencial)	A1, A2	35	90	62-Alto (potencial)	Vulnerabilidad conocida pero mitigada en pruebas
R6	Enumeración de usuarios SMTP	A2	10	15	12-Inf	Controles adecuados implementados
RT	Promedio de riesgo general de los escenarios evaluados				61-Alto	

2. Puntos de mejora: A continuación, se enumeran las recomendaciones y modificaciones recomendadas para reducir la probabilidad de ocurrencia y minimizar el nivel de impacto.

- Homologación de controles de seguridad: Implementar un modelo centralizado de seguridad que defina estándares mínimos obligatorios para todos los activos, independientemente de su ubicación o responsable operativo.
- Gestión e inventario de activos: Establecer un proceso continuo de inventario y clasificación de activos para asegurar que todos los sistemas expuestos estén debidamente identificados y protegidos dentro del perímetro de seguridad.
- Gestión de vulnerabilidades y actualización tecnológica: Definir un proceso formal de parcheo y actualización para eliminar tecnologías en estado EOL, reduciendo la exposición a vulnerabilidades conocidas.
- Control de accesos y segmentación de red: Asegurar que cualquier acceso a servicios críticos se realice mediante listas de control de acceso (ACL), VPN o segmentación de red, evitando exposición directa a internet.
- Centralización del tráfico a través del WAF: Asegurar que todo el tráfico externo hacia servicios críticos sea forzado a pasar por los mecanismos de inspección y protección definidos.

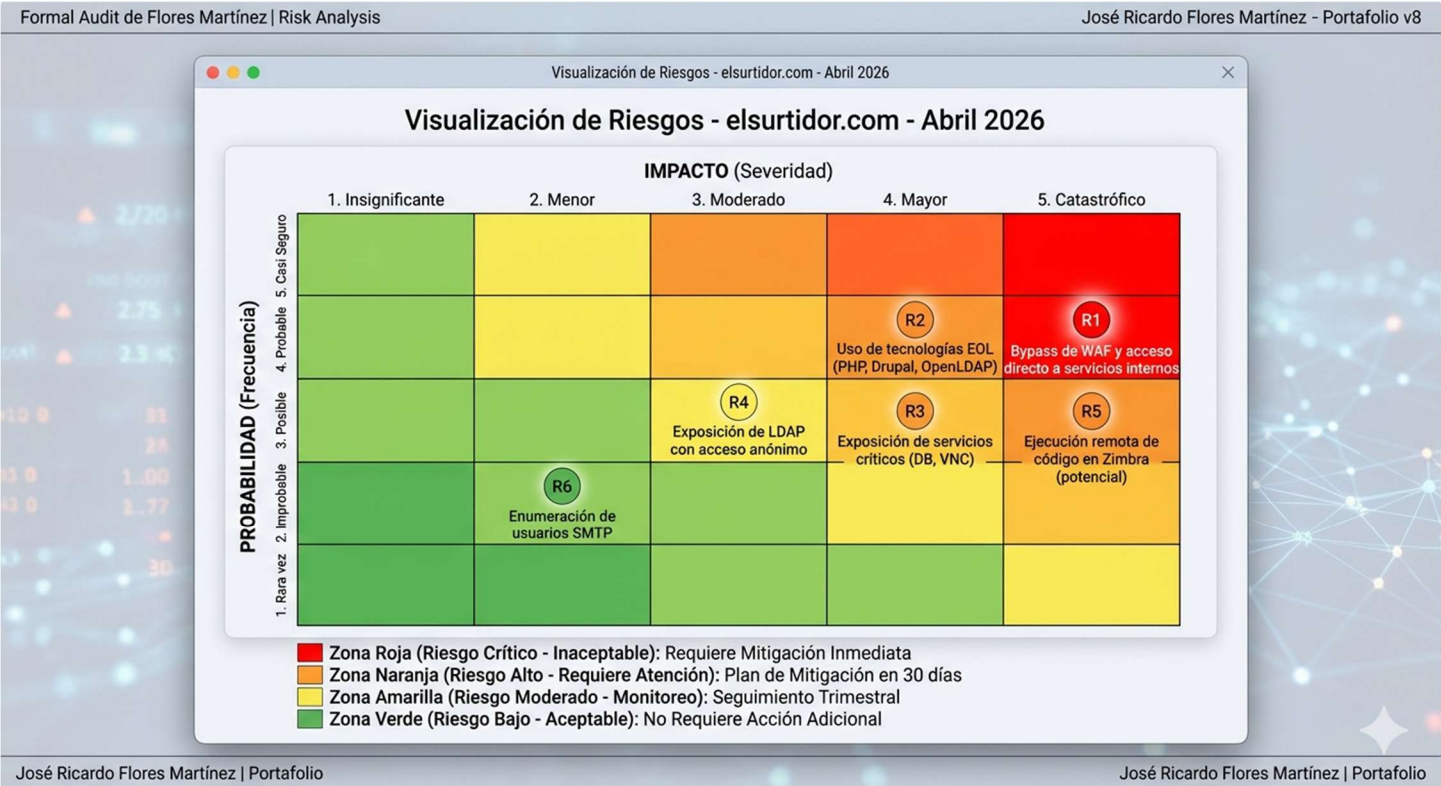
3. Plan y opciones de tratamiento de riesgos: A continuación, se enumeran las opciones recomendadas para el tratamiento de los riesgos identificados con el objetivo de reducir el impacto o la probabilidad de ocurrencia. Las estrategias de tratamiento a considerar son las siguientes.

ID Riesgo	Nivel	Tratamiento	Acción recomendada	Prioridad	Plazo recomendado	Responsable
R1 – Elusión WAF	Crítico	Evitar / Mitigar	Forzar todo el tráfico a través del WAF, eliminar acceso directo por IP, implementar ACL restrictivas	Inmediata	10-15 días	Sistemas
R2 – Tecnologías EOL	Crítico	Mitigar	Actualizar PHP, Drupal, OpenLDAP a versiones soportadas	Alta	90 días	Sistemas-Dirección
R3 – Servicios expuestos	Alto	Evitar	Cerrar puertos innecesarios, restringir acceso mediante VPN o segmentación	Alta	10-15 días	Sistemas
R4 – LDAP anónimo	Medio	Mitigar	Deshabilitar Anonymous Bind, aplicar autenticación obligatoria	Media	30 días	Sistemas
R5 – RCE Zimbra (potencial)	Alto	Mitigar / Aceptar (temporal)	Validar versión, aplicar parches, monitorear actividad	Media	90 días*	Sistemas
R6 – SMTP enumeration	Informativo	Aceptar	Mantener controles actuales	Baja	Recurrente - Continuo	Sistemas

Las estrategias de tratamiento consideradas son:

- Mitigar: Reducir el riesgo mediante controles técnicos u organizativos
- Evitar: Eliminar la condición que genera el riesgo
- Transferir: Delegar el riesgo a un tercero
- Aceptar: Asumir el riesgo dentro del nivel permitido

Img. 1: Mapa de calor y prioridad de los riesgos evaluados.



Las acciones recomendadas para el tratamiento de los riesgos evaluados se detallan a continuación.

R1 – Elusión WAF: Eliminación de accesos directos que permitan evasión del WAF, así como la confirmación de implementación de ACL restrictivas para forzar que toda comunicación pase por el filtro.

KPI Inmediato: Inventario de puertos abiertos y servicios accesibles, mantener únicamente aquellos que justifiquen completamente la necesidad de acceso dentro de los primeros 7 días después de la entrega de este reporte.

KPI recomendado: Asegurar que el 100% del tráfico pase por el WAF, confirmar la implementación de listas blancas de acceso asegurando el acceso únicamente desde direcciones de confianza.

R2 – Tecnologías EOL: Se propone actualizar las tecnologías identificadas como obsoletas a versiones seguras o en su defecto sustituirlas por tecnologías equivalentes actuales. Se da un plazo extendido en esta opción teniendo en cuenta la necesidad de pruebas de compatibilidad, análisis y asignación de presupuesto y posibles impactos en la continuidad del negocio.

KPI Inmediato: Dentro de los primeros 15 días hábiles después de la entrega del presente reporte se debe confirmar la aplicación de los parches de seguridad correspondientes a las versiones actuales.

KPI recomendado: Actualizar servicios por lo menos a sus versiones con soporte oficial activo a más tardar 6 meses después de su liberación. Cualquier servicio que no pueda ser actualizado deberá ser documentada para evaluar el riesgo derivado contra la desviación de tolerancia al riesgo.

R3 – Servicios expuestos: Actualizar el inventario de puertos, deshabilitar aquellos que se identifiquen como innecesarios y restringir el acceso mediante la implementación de VPNs o segmentación de red.

KPI Inmediato: Dentro de un periodo de 15 días después de la entrega del presente informe se confirmará la implementación de un inventario de puertos indicando el servicio que albergan y control de acceso implementado.

KPI recomendado: Reducir la cantidad de puertos expuestos en un 80%. Realizar un análisis de riesgo para cada nueva aplicación que requiera habilitar un puerto de comunicación.

R4 – LDAP anónimo: Deshabilitar conexiones anónimas, configurar autenticación obligatoria para todos los accesos y enmascarar o limitar información sensible de los servicios.

KPI recomendado: Eliminar el acceso anónimo en todos los sistemas críticos en los próximos 3 meses.

R5 – RCE Zimbra (potencial): Validar la versión actual y asegurar la aplicación de todos los parches de seguridad correspondientes. Mantener monitoreo continuo de actividad mientras se realiza la migración de Drupal 7/PHP 7.4 (que puede ser costosa), se propone como control compensatorio inmediato el aislamiento estricto del segmento de red y el monitoreo intensivo de logs en el Nginx frontal.

KPI Inmediato: Confirmar la implementación del paquete *PHP7.4-cli* así como la configuración en el archivo *httpd.conf* (causantes comunes del error con el corrector ortográfico *zimbra-spell*).

KPI recomendado: Implementar un proceso de actualización mensual, confirmando la liberación de parches y actualizaciones e implementándolas a más tardar 30 días después de su liberación.

R6 – SMTP enumeration (Informativo): Mantener los controles actuales, pero incluir en el ciclo de auditoria recomendado para futuras modificaciones o actualizaciones.

KPI recomendado: Implementar un proceso de auditoria anual de controles, análisis de activos y configuraciones, etc. así como una confirmación de configuración cada vez que se realice una actualización.

4. Modelado de amenazas (posibles escenarios de ataque):

A continuación, se detallan los posibles escenarios de explotación de las amenazas consideradas como críticas. Es imperativo señalar que si bien, cada escenario presenta un riesgo individual, la explotación grupal de estas vulnerabilidades podría generar un caso de ataque en cadena (**kill chain**) el cual tiene la posibilidad de comprometer más de un activo de la organización (initial Access – Pivoting – Lateral movement).

Los escenarios fueron modelados considerando patrones de ataque documentados en CAPEC y debilidades estructurales definidas en CWE (según corresponda) las cuales se indican aquí para su consideración en el proceso de remediación. Estos escenarios representan **hipótesis** de ataque construidas a partir de las condiciones de riesgo identificadas, su inclusión no implica que el compromiso descrito haya sido demostrado durante la auditoría, salvo cuando se indique expresamente.

Descripción de la amenaza	Information Disclosure: Fuga de información confidencial.
Elusión Waf + Compromiso de correo (Riesgo R1)	Un atacante logra detectar la dirección IP real del servidor mediante fuentes abiertas accediendo directamente al panel de acceso ZIMBRA y mediante ataques de fuerza bruta, password spraying o ataques dirigidos, accede a las cuentas de correo almacenadas en el servidor.
Objetivo	Acceso a direcciones de correo corporativas para ataques de pishing interno, envío de correo a clientes y proveedores solicitando información confidencial, movimiento lateral a otros activos.
Severidad típica	Crítica: Acceso directo no mediado por el control perimetral WAF confirmado
Técnicas de ataque	Ataques de fuerza bruta, password spraying, credential stuffing, suplantación de identidad simulando ser parte del equipo de IT.
Patrón de ataque CAPEC	CAPEC-554: Functionality bypass. El atacante evade una o varias protecciones de un sistema
Código CWE	CWE-284: Improper Access Control. El software o en este caso el servicio Zimbra no restringe correctamente las acciones o el acceso a recursos por parte de actores no autorizados.
Caso de abuso (hipotesis)	Activos A1 y A2: Un atacante detecta la IP directa del servidor y accede al panel de acceso del servicio accediendo a información privilegiada y dependiendo de la configuración del servicio, obteniendo acceso de administrador de las cuentas de correo de la organización.
Consecuencias probables	Pérdida de confianza de clientes y proveedores, interrupción de la cadena de suministros, alto impacto en la reputación, ventas y cumplimiento legal.
Medidas de mitigación recomendadas	Asegurar que el 100% del tráfico a todos los activos de la red pasen por el servicio WAF e implementar una lista de direcciones IP en el firewall interno que acepte únicamente direcciones oficiales de CLOUDFLARE pertenecientes al rango asignado.

Descripción de la amenaza	Information Disclosure: Fuga de información confidencial / Tampering: Manipulación de datos o código de la aplicación. El atacante identifica servicios expuestos lo que permite identificar vulnerabilidades específicas para las versiones implementadas y acceso a la VNC lo que permitiría pivotar a otros activos de la organización y posiblemente comprometiendo mas de un activo.
Exposición de servicios críticos + Acceso interno indirecto (Riesgo R4)	
Objetivo	Acceder a la base de datos para descargar información y/o modificar datos específicos de manera maliciosa
Severidad típica	Alta: Múltiples servicios expuestos.
Técnicas de ataque	Ingresar scripts en la base de datos que al ser consultados por una aplicación que permita etiquetas de tipo <i>script</i> para que la página HTML la interprete (Cross Site Scripting Almacenado) e Inyecciones SQL / El VNC abierto permitirían ejecutar acciones de manera remota habilitado el control de un dispositivo desde otro dentro de la red (Pivoting)
Patrón de ataque CAPEC	CAPEC-555: Remote services with stolen credentials. Uso de credenciales filtradas para ejecución de servicios remotos (SSH,VNC,Etc.) / CAPEC-592: Stored XSS. Inyección de secuencias de comandos maliciosos almacenadas en la BDD de manera persistente.
Código CWE	CWE-284: Improper Access Control. El sistema no restringe correctamente el acceso a recursos por parte de actores no autorizados (El acceso a la BDD, fuga de información de la VNC para LDAP) / CWE-200: Exposure of Sensitive Information: Un producto revela información confidencial (LDAP) a usuarios, procesos o sistemas no autorizados.
Caso de abuso (hipotesis)	Activos A1 y A3: El atacante ingresa scripts como campos en la base de datos que al ser interpretados y ejecutados permitiría el robo de sesiones, redirección de usuarios o descarga de datos críticos. El acceso a la VNC abierta permitiría obtener la lista de usuarios y permisos asignados facilitando la toma de control de un ordenador para enviar comandos y ejecutar acciones de administración.
Consecuencias probables	Acceso a datos de clientes, empleados, pedidos, mercancías, información operativa o cualquier información almacenada en la BDD, Impacto potencial en operación, cumplimiento normativo y legal.
Medidas de mitigación recomendadas	Implementar una ACL que permita el acceso a la VNC únicamente desde las direcciones IP pertenecientes al rango de la VPN corporativa o una whitelist de IPs externas en caso de administración remota. Asegurar la sanitización de datos en la BDD para asegurar que no permita XSS y limitar la capacidad de modificación de campos solo a usuarios específicos.

Descripción de la amenaza	Spoofing: Suplantación de identidad / Elevation of privilege: Elevación de privilegios / Repudiation: Repudio de responsabilidad. Acceso inicial mediante elusión del WAF o la VNC expuesta, Enumeración de usuarios (LDAP) y estructura interna, Identificación y explotación de servicios vulnerables (Aplicaciones sin soporte o en estado EOL), Movimiento lateral dentro de la red.
Ataque en cadena y pivoteo hacia la infraestructura vulnerable (Riesgo R1,R2, R3 Y R4)	
Objetivo	El proceso de ataque encadenado busca utilizar varias condiciones de riesgo individuales para lograr comprometer uno o más dispositivos de la red y posteriormente alcanzar activos de mayor valor (acceso inicial, enumeración, explotación, movimiento lateral y persistencia)
Severidad típica	Crítica
Técnicas de ataque	Al identificar aplicaciones vulnerables sin soporte activo, se pueden detectar vulnerabilidades específicas para la mismas. La explotación de estas vulnerabilidades para obtener acceso a un dispositivo, instalación de malware y modificación de los sistemas de protección.
Patrón de ataque CAPEC	CAPEC-115: Authentication bypass. Acceso a aplicaciones, servicios o dispositivos sin superar las verificaciones de seguridad. / CAPEC-576: Group Permission Footprinting. Explotar funciones legítimas para identificar grupos, usuarios y permisos de sistema. / CAPEC-555: Remote services with stolen credentials. Uso de credenciales filtradas para ejecución de servicios remotos (SSH,VNC,Etc.)
Código CWE	CWE-1104: Use of Unmaintained Third-Party Components. El sistema confía en componentes de terceros que ya no tienen soporte activo o mantenimiento del desarrollador original. / CWE-693: Protection Mechanism Failure. El sistema no utiliza o utiliza de manera incorrecta los mecanismos de protección o defensa.
Caso de abuso (hipótesis)	Activo A3: Un atacante utiliza los datos obtenidos aprovechando la elusión del WAF a través de uno de los activos accesibles directamente, junto a la información de usuarios obtenida (LDAP) para explotar el acceso de servicios expuestos como VNC para enviar comandos maliciosos a otros dispositivos dentro de la red, iniciar conexión con dispositivos fuera de la red (reverse connection), descargar e instalar programas maliciosos y/o modificar las configuraciones internas para asegurar el acceso persistente.
Consecuencias probables	Compromiso de uno o varios dispositivos de la red con una posible afectación progresiva (dependiendo de los controles internos), alto impacto en ventas, continuidad operativa y exfiltración de información confidencial según los activos afectados.
Medidas de mitigación recomendadas	Implementar segmentación de red (VLANs) para aislar activos críticos y limitar el posible movimiento lateral. Establecer un cronograma de auditoría y actualización para aplicaciones EOL y reforzar el monitoreo de logs para detectar intentos de conexión reversa.

5. Propuesta de seguimiento:

Se Propone una reunión de seguimiento a los 180 días posteriores a la aceptación del presente informe para confirmar la implementación de las medidas recomendadas o evaluar las alternativas seleccionadas por los departamentos correspondientes.

6: Conclusiones:

El proceso de análisis realizado confirma que la organización cuenta con un nivel de madurez intermedio, considerando que la aplicación y configuración de controles es bastante fuerte, sin embargo, no es extensivo de manera homogénea a todos los activos / localidades generando brechas de seguridad importantes que pueden pasar desapercibidas al no contar con un modelo de control de seguridad centralizado.

También se observa la necesidad de fortalecer la inversión en tecnología y actualización de servicios considerando que el costo de remediación en caso de materialización de uno o más de los riesgos señalados, podría sobrepasar considerablemente el costo de actualización del sistema o afectaciones del negocio como interrupción del proceso de ventas, pérdida de confianza de clientes, etc.

Considerando que los riesgos identificados no se limitan a un solo activo, sino que se generan por la exposición estructural de varios activos fuera del perímetro de protección posibilitando la evasión de controles y la posible ejecución de ataques encadenados, se recomienda la implementación de un proceso de homologación de criterios de seguridad.

7. Limitaciones y descargo de responsabilidad:

El presente análisis se basa en la información recopilada del proceso de auditoría técnica de seguridad ejecutado durante el periodo comprendido entre el 01 y el 14 de junio de 2026, bajo un enfoque de auditoría de caja negra y sin acceso interno a la infraestructura.

Los resultados y conclusiones están limitados a los activos identificados durante el proceso de auditoría, por lo que podrían existir otros sistemas o condiciones de riesgo no detectadas o fuera del alcance definido.

Este informe no garantiza la ausencia total de vulnerabilidades o riesgos en la infraestructura evaluada, sino que representa una evaluación puntual basada en las condiciones observadas durante el periodo de análisis.

La implementación de las recomendaciones propuestas reduce la probabilidad e impacto de los riesgos identificados, pero no elimina completamente la posibilidad de incidentes de seguridad.